

INTERNAL

AI Lifecycle Policy

2 July 2026

Status
Security
Version No.
Approved by
Author(s)

Approved
Company Restricted
2.0
CAIO/CIO/CISO
AI/GRC Teams

Contents

- 1. Introduction..... 1**
 - 1.1 Policy Summary 1
 - 1.2 AI Development Objectives 1
 - 1.3 Scope 1
- 2. Definitions & Controls 2**
 - 2.1 Risk Tier Definitions 2
 - 2.2 Tier 1 Controls..... 3
 - 2.3 Tier 2 & 3 Controls..... 4
 - 2.4 Tier 3 Controls..... 5
- 3. Lifecycle Stages 6**
 - 3.1 Discovery 6
 - 3.2 Design 6
 - 3.3 Development 7
 - 3.4 Deployment & Operations 7
 - 3.5 Retirement..... 7
 - 3.6 Responsible AI 7
- 4. Mandatory Documentation 9**
- 5. Responsibilities..... 10**
- 6. Compliance 11**
 - 6.1 Exceptions..... 11
 - 6.2 Compliance Measurement 11
 - 6.3 Non-Compliance 11
 - 6.4 Monitoring & Review 11
- 7. Document Information 12**
 - 7.1 Changes History 12
 - 7.2 References 12
 - 7.3 Terms & Abbreviations..... 12

1. Introduction

This policy sets the minimum controls Kainos applies to develop and operate AI responsibly and in line with ISO/IEC 42001. It covers the full AI lifecycle, and the level of control required based on the system's risk tier.

This policy works alongside but does not replace existing SDLC, security, privacy, and operational governance and delivery processes.

1.1 Policy Summary

The following is a list of key points relating to this policy:

- The document defines the Kainos AI Lifecycle;
- It specifies 12 mandatory controls (C1-C12);
- Includes 4 core assurance artefacts to capture evidence of each control; and
- A Risk Tier classification which enables the selection of appropriate controls.

1.2 AI Development Objectives

All AI systems developed by Kainos should be designed to meet the following objectives. These are achieved via the controls in brackets listed against each objective.

- **Fairness.** Testing and mitigating bias should be implemented so outputs do not unfairly disadvantage protected groups (C5, C6).
- **Accountability.** A named Owner and Approver should exist for each AI system (C3, C8).
- **Transparency.** Each system's intended use, limitations and key design choices should be documented and easy to find (C4, C9).
- **Reliability and robustness.** Systems should be designed to work as intended under normal use, adversarial conditions and foreseeable misuse (C5, C6, C14).
- **Security.** Appropriate security controls should be built in from the start, including controls against prompt injection and data exfiltration (C5, C7).
- **Privacy.** Personal and sensitive data must be handled in line with Data Protection Regulations and handled it under the Data Management Record (C2).
- **Explainability.** Outputs should be explained to a depth that matches the use case and risk tier (C4, C9).
- **Maintainability.** The system should be operated, monitored and retired in a controlled manner (C7, C10, Retire stage).

1.3 Scope

Important: This policy applies only to engagements where Kainos is contractually responsible for the design, development, configuration, deployment, or operation of an AI system, AI-enabled solution, or AI product intended for production or operational use by a customer or internal business function.

This includes projects where AI capabilities form a material component of the delivered solution and where Kainos has accountability for the behaviour, performance, or outcomes of the AI system. It also includes Third-party AI services consumed by Kainos or its clients (e.g. commercial LLM APIs, vendor models, retrieval services).

2. Definitions & Controls

Kainos applies a risk-based approach to AI engagements. This ensures that an appropriate set of controls are selected for each engagement based on the AI Risk Tier, which is described in the Section 2.1.

Every AI system shall be classified at the Discovery stage (described in Section 3.1) into one of three tiers. The risk tier determines the level of control evidence required as part of the solution delivery.

Note: The risk tier will be assigned by AI Governance Forum during the AI System Impact Assessment review.

2.1 Risk Tier Definitions

Below is a definition of the AI Risk Tiers.

Tier	Indicative criteria	Examples	Control depth
Tier 1 - Low	Internal use only; non-decisional; no personal or sensitive data; reversible outputs.	Internal productivity assistants; code completion tools	Minimal (see 2.2)
Tier 2 - Medium	Customer-facing or decision-support; processes personal or commercially sensitive data. Or, regulated industry but non-critical functions.	Customer chat assistants; document summarisation; classification with human review	Full set of 12 standard controls. (see 2.3)
Tier 3 - High	Decision-making, vulnerable users, or EU AI Act Annex III high-risk use. Or, high-stakes sectors.	Eligibility decisions; recruitment screening; medical triage support	Full set of standard controls PLUS enhanced controls. (see 2.4)

2.2 Tier 1 Controls

All Tier 1 systems must address the AI Lifecycle controls listed below. As the risk level is low the level of information recorded can be kept to a minimum and may be captured in a **single AI System Register entry**; however all controls must be assessed to demonstrate they have been considered.

Note: A separate four-artefact pack is **NOT** required. The entry covers the six items below; each may be one paragraph or less. The same standard controls C1-C12 apply - only the depth changes due to the risk being low.

#	What you record	What "good" looks like at Tier 1	Standard controls covered
1	Purpose & users - what the system is, who uses it, why AI	Problem statement, intended internal users, confirmation outputs are non-decisional and reversible.	C1, C4
2	Data - what data the system processes	Confirmation no personal or commercially sensitive data is processed; named source(s); no customer data leaves the approved tenant.	C2
3	Ownership - who owns it, who approved it	Named Accountable Owner. Tier 1 only: the Owner may also act as Approver.	C3, C8
4	Risk - what could go wrong and how it's managed	Short risk note covering AI threats (bias, prompt injection, leakage, drift), foreseeable misuse, mitigations, and the Owner's acceptance of residual risk.	C5
5	Operation - how we know it works and stays safe	Smoke test against pre-stated criteria; standard platform logs retained; annual lightweight review; incidents handled under the standard incident process.	C6, C7, C10, C11
6	Users & end-of-life - what users see, when we retire it	Short user note (intended use, limits, how to raise issues); retirement trigger recorded.	C9, Retire

2.3 Tier 2 & 3 Controls

The following controls **MUST** be implemented for **tier 2 and 3** projects at the relevant lifecycle stages.

ID	Requirement	Evidence Artifact	Lifecycle Stage
C1	AI System Impact Assessment completed before development.	Risk & Impact Assessment	Discovery
C2	Data Management Record covering sources, sensitivity, quality, provenance.	Data Management Record	Discovery
C3	Accountabilities and competence documented (Owner, Approver, Reviewers).	AI System Register; Approvals & Exceptions log	Discovery
C4	AI System Description capturing architecture, model rationale, design decisions.	AI System Description	Design
C5	AI Risk Assessment and Treatment Plan (including. foreseeable misuse) approved with residual risk accepted.	Risk & Impact Assessment	Design
C6	Validation and verification evidence proportionate to risk tier with documented acceptance criteria.	Monitoring & Review Record	Development
C7	Event logging for inputs, outputs, tool/agent actions, decisions; protected from unauthorised changes.	AI System Description	Development
C8	Documented pre-deployment approval (acceptance, rollback, readiness).	Approvals & Exceptions log	Deployment
C9	User and operator information (intended use, limitations, redress).	AI System Description	Deployment
C10	Monitoring & Review Record maintained at risk-proportionate intervals.	Monitoring & Review Record	Operate
C11	AI incidents managed under organisational incident response.	Monitoring & Review Record	Operate
C12	Core artefacts retained under documented information control; producible to internal audit, regulators, customers, and conformity assessors.	AI System Register linking the four artefacts	All
-	Retirement plan documented (decision criteria, data disposal, archival, communication).	AI System Description	

2.4 Tier 3 Controls

As Tier 3 projects may be considered higher risk the following additional controls **MUST** be implemented.

ID	Requirement	Expected evidence
C13	Independent review of Risk and Impact Assessment.	Reviewer sign-off in Approvals & Exceptions log
C14	Adversarial / red-team testing.	Test report in Monitoring & Review Record
C15	Post Go-live monitoring plan.	Section of Monitoring & Review Record

3. Lifecycle Stages

The following sections define the stages, controls and outputs expected in a Kainos AI Delivery Engagement.

Important: Mandatory documentation requirements are detailed in each section. A summary overview of each artefact is presented in Section 4.

3.1 Discovery

This stage clarifies the problem, intended users, success criteria, constraints, data landscape and risk tier.

The following controls apply:

- C1 AI System Impact Assessment.** Complete an AI System Impact Assessment before development or procurement begins, recording the problem statement, intended use, in-scope users, assigned risk tier, and the rationale for using AI (including why a non-AI approach was not chosen).
- C2 Data Management Record.** Create a Data Management Record for all data used to build, train, or operate the system, identifying data sources and categories (flagging any personal or sensitive data), provenance and lawful basis, quality and limitations, and handling, retention, and access rules.
- C3 Accountabilities and Competence.** Document and assign accountabilities before the system is approved for use, naming the Accountable Owner and Approver and defining the competences required to build, operate, and oversee the system.

For Tier 2 and Tier 3 systems, the C1 Impact Assessment and C5 Risk Treatment shall also cover societal impact.

3.2 Design

This stage translates the Discovery Stage outputs into a solution architecture, model and component choices with an approved risk treatment plan.

The following controls apply:

- C4 AI System Description.** Draft an initial AI System Description (model/system card) capturing the architecture, the rationale for model and component selection, and all material design decisions.
- C5 AI Risk Assessment and Treatment Plan.** Approve the AI Risk Assessment and Treatment Plan that addresses AI-specific threats (bias, prompt injection, data leakage, drift), foreseeable misuse scenarios, mitigations, and the accepted residual risk.

3.3 Development

This stage ensures the development of the system against the design and demonstrates control effectiveness through verification and validation proportionate to risk tier.

The following controls apply:

- C6 Verification and Validation.** Perform verification and validation (V & V) against agreed acceptance criteria proportionate to the risk tier. V&V should cover functional accuracy, non-functional requirements, safety, fairness, and the effectiveness of C5 controls with fairness and harmful-output evaluation methods applied proportionately.
- C7 Event Logging.** Implement event logging sufficient to reconstruct inputs, outputs, tool/agent actions, and material decisions. Logs must be tamper-protected, access-controlled, retained per the Data Management Record, and reviewed at risk-proportionate intervals.

3.4 Deployment & Operations

This stage ensures controlled release, appropriate user and operator documentation, effective monitoring, incident response readiness and continuous improvement.

The following controls apply:

- C8 Pre-Deployment Approval.** Record a documented pre-deployment approval confirming acceptance against criteria, residual risk acceptance (where applicable), deployment environment readiness, a rollback plan.
- C9 User and Operator Information.** Publish user and operator information covering the intended use, limitations, oversight expectations, and the channel for raising issues.
- C10 Monitoring and Review.** Maintain a monitoring and review Record capturing performance, safety, drift, and incident indicators at risk-proportionate intervals.
- C11 Incident Management.** Manage AI-related incidents under a defined incident response process, ensuring reporting serious harms in line with applicable contractual and legislative regulations.
- C12 Information Control.** Implement document control of the four core artefacts detailed in Section 4.

Change management: any material change to a deployed AI system - including model upgrade, retraining on new data, change of underlying third-party service, or change of intended use - shall trigger re-run of C5 (risk re-assessment) and C8 (re-approval) before the change is released.

3.5 Retirement

AI systems shall have a documented retirement plan covering the decision criteria for retirement (e.g. business obsolescence, unacceptable drift, regulatory change, vendor end-of-life), user and operator communication, data disposal aligned to the Data Management Record, model and artefact archival, log retention through the retention window, and any ongoing obligations (e.g. ability to respond to data subject rights requests post-decommissioning). The retirement plan is recorded in the AI System Description and executed under documented information control (C12).

3.6 Responsible AI

Responsible AI means applying these controls consistently across the lifecycle of each AI system. The same expectations apply whether the system is classical ML, an LLM, or an agentic workflow. The table below shows how these Responsible AI themes are applied through the Kainos AI lifecycle.

Theme	Description	Implemented by
Integrity	How Kainos ensures an AI solution is designed to be secure, including protection against prompt attacks and control over where data is stored and processed.	C5, C7, C14
Trustworthy	How Kainos ensures an AI solution is tested for bias and accuracy, transparent about how it works, with guardrails and explanations users can understand.	C4, C6, C9
Ethical	How Kainos ensures an AI solution is designed and used in ways that benefit people and avoid social or environmental harm.	C1, C5,
Governance & Compliance	How Kainos ensures an AI solution meets our internal governance requirements and applicable regulations.	C8, C12
Human-Centric	How Kainos ensures an AI solution keeps people in control and supports, rather than replaces, human judgement.	C9, C11

4. Mandatory Documentation

The four artefacts below are the only mandatory deliverables. They evolve through the lifecycle and shall be linked from a single AI System Register entry.

For Tier 1 systems the four artefacts may be condensed into a single **AI System Register pack** as set out in section 2.2.

Artefact	Purpose	Controls
AI System Description (Model/System Card)	To document what the system is, how it works, what it uses, and its limitations. Includes architecture, training data lineage, hyperparameters, dependencies, non-functional requirements, and retirement plan.	C4, C7, C9
Risk & Impact Assessment	To document the intended use, risk classification, threats, foreseeable misuse, mitigations, and residual risk acceptance.	C1, C5
Data Management Record	To keep a record of data sources, categories, provenance, quality, and handling rules.	C2
Monitoring & Review Record	To retain a record of operational and review activities covering validation and verification outcomes (against pre-stated acceptance criteria), monitoring metrics, incidents and log reviews.	C6, C10, C11

A supporting Approvals & Exceptions log records pre-deployment approvals (C8), accountabilities (C3), and approved deviations.

5. Responsibilities

All Kainos staff and contractors delivering or operating AI solutions are responsible for adhering to this policy. Each AI system may have:

- **Accountable Owner.** Owns the system and the AI System Register entry.
- **Approver.** Authorises stage transitions and pre-deployment release; for Tier 2 and Tier 3, the Approver shall not be the Accountable Owner.
- **Reviewer(s).** Functional experts (Security, Data/AI Ethics, QA, Legal) recorded against the relevant control.

The following roles should be considered in an AI Delivery. A single individual may have more than one role depending on the size and complexity of the engagement.

Role	Key obligations	Competence
Product / Delivery Manager	Stage-gate ownership; AI System Register entry; adoption & change management.	Lifecycle, tier-based evidence expectations.
Data Science / AI Engineering	AI System Description; guardrails, validation, logging; incident & retraining support.	Model design, AI threats, V&V methods.
Security	Risk & Treatment Plan input; red-team / adversarial testing for Tier 3; alignment to Min Sec Requirements.	AI threat modelling, secure ML/LLM deployment.
Quality Assurance	V&V vs. acceptance criteria; go/no-go; regression, bias, adversarial coverage.	Acceptance criteria for probabilistic systems.
Data/AI Ethics / Legal / Compliance	RIA & DPIA review; diverse voices in Discovery; regulatory advice.	EU AI Act, GDPR, sector frameworks.

Note: Depending on the scale and nature of the project, not all roles and associated responsibilities defined within this policy may be formally assigned or fulfilled

6. Compliance

6.1 Exceptions

Deviation from this policy will be by exception and require formal approval of the Chief Technology Officer (or equivalent authority) in consultation with the Chief Information Security Officer and the AI Governance function.

6.2 Compliance Measurement

The AI Governance Forum will verify compliance to this policy through methods such as periodic audits, inspection of the four core artefacts, and review of the Approvals & Exceptions log.

Any user who suspects that any portion of this policy has been breached or would like confirmation if an action falls inside the purview of this policy should contact their people manager in the first instance, who may refer the user to the AI Governance Forum.

6.3 Non-Compliance

Kainos reserves the right to follow standard disciplinary procedures for breaches of this policy, up to and including termination of employment or contract.

6.4 Monitoring & Review

This Policy shall be maintained, reviewed, and updated by the AI Governance Forum. This review shall take place at planned intervals (not less than annually), or sooner where regulatory or technological change requires it. Outputs from operational Monitoring & Review Records feed the Clause 9.3 management review.

Suggested updates to this policy should be forwarded to the AI Governance team.

7. Document Information

7.1 Changes History

Issue	Date	Description
1.0	05.06.26	Initial approved version.
2.0	02.07.26	DC; Corrected typo on front cover.

7.2 References

Ref	Title	Version
1	ISO/IEC 42001 - AI Management System	2023
2	ISO/IEC 23894 - Guidance on risk management for AI	2023
3	EU AI Act (Regulation 2024/1689)	2024
4	NIST AI Risk Management Framework	1.0
5	OWASP LLM Top 10	2025
6	Kainos Minimum Security Requirements	Current

7.3 Terms & Abbreviations

Term/Abbreviation	Meaning
AI	Artificial Intelligence
AI Ops	Operational practices spanning MLOps, LLMOps, and AgenticOps
AIMS	AI Management System
Annex A	ISO/IEC 42001 Annex A reference controls
Annex B	ISO/IEC 42001 Annex B - informative implementation guidance
DPIA	Data Protection Impact Assessment
LLM	Large Language Model
ML	Machine Learning
PII	Personally Identifiable Information
RAG	Retrieval Augmented Generation
TEVV	Testing, Evaluation, Verification, Validation
Tier	Risk classification (Low / Standard / High) assigned at Discover

kainos®

